

Chapter 14: Authentication & Identity Management

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

Learning Objectives

- Understand **authentication, authorization, and accounting (AAA)**
- Describe **multi-factor authentication (MFA)** mechanisms
- Explain **Single Sign-On (SSO)** and **Federated Identity Management (FIdM)**
- Compare **access control models** (DAC, MAC, RBAC, ABAC)
- Review **identity lifecycle management** and **best practices**

Overview

Authentication and identity management ensure that **only authorized users** access systems and data.

Goal:

- Verify **who** the user is (Authentication)
- Determine **what** they can do (Authorization)
- Track **what** they did (Accounting)

This is the foundation of all secure systems.

The AAA Framework

Function	Description	Example
Authentication	Verifies user identity	Username/password, biometrics
Authorization	Grants access rights	File permissions, role access
Accounting (Auditing)	Tracks user activity	Logs, session duration, changes

 AAA ensures accountability and non-repudiation.

Authentication Factors

Authentication relies on **something you...**

Factor Type	Example
Know	Password, PIN, security question
Have	Smart card, token, mobile device
Are	Biometrics (fingerprint, iris, face)
Do	Typing pattern, gestures
Are (where)	Geolocation, IP address, GPS

 Combining **two or more factors** = **Multi-Factor Authentication (MFA)**

Multi-Factor Authentication (MFA)

Definition:

Requires at least two different authentication factors from separate categories.

Examples:

- Password + OTP (mobile app or SMS)
- Smart card + PIN
- Biometric + token

Advantages:

- Reduces risk of credential theft
- Protects against phishing and replay attacks



MFA = stronger identity assurance.

One-Time Passwords (OTP)

Types:

- **TOTP (Time-based OTP):** expires every 30–60 seconds
- **HOTP (HMAC-based OTP):** counter-based; changes each login

Delivery Methods:

- Hardware tokens (RSA SecurID)
- Mobile apps (Google Authenticator, Microsoft Authenticator)
- SMS or email (less secure)

Best Practice: use **TOTP-based apps** over SMS for higher security.

Context-Aware Authentication

Adaptive authentication adds contextual checks:

- Device fingerprint
- Location and time of login
- User behavior patterns

 Example: prompt for MFA only if login is unusual (e.g., new device or location).

Biometric Authentication

- Uses **unique physiological or behavioral traits**
- Common examples: fingerprint, iris, facial recognition

Metrics:

Term	Description
FAR (False Acceptance Rate)	Unauthorized user accepted
FRR (False Rejection Rate)	Authorized user rejected
CER (Crossover Error Rate)	Equal error point; lower = better

 Combine biometrics with PINs or tokens for multi-layered assurance.

Password Management

Password Best Practices:

- Minimum 12–16 characters
- Mix of uppercase, lowercase, numbers, and symbols
- Avoid common words or reused credentials
- Enforce periodic rotation and complexity rules

Password Managers:

- Encrypt and store credentials securely
- Should be protected by MFA or master password

Authorization Principles

After authentication, users must be authorized to perform actions.

Principles:

- **Least Privilege:** grant only required access
- **Separation of Duties:** divide critical tasks among multiple people
- **Job Rotation:** reduce collusion risk and increase cross-training
- **Privileged Access Management (PAM):** secure admin credentials

 *Access control defines “who can do what, where, and when.”*

Access Control Models

Model	Description	Example
DAC (Discretionary Access Control)	Owner decides permissions	Windows NTFS permissions
MAC (Mandatory Access Control)	Access based on classification level	Military/government systems
RBAC (Role-Based Access Control)	Access tied to organizational role	Finance, HR, IT roles
ABAC (Attribute-Based Access Control)	Access based on attributes (user, object, environment)	Context-aware IAM systems

 Modern systems often blend **RBAC** and **ABAC** for flexibility.

Role-Based Access Control (RBAC)

Concept: permissions are assigned to roles, not individual users.

Example:

Role	Permissions
HR Manager	Read/Write Employee Records
Finance Staff	Access Payroll System
IT Support	Reset User Passwords

 Easier to manage than per-user permissions.



Attribute-Based Access Control (ABAC)

- Uses **policies combining multiple attributes** (user, resource, environment).

- Example policy:

Allow access **IF** Department = Finance **AND** Location = Head Office
AND Time < 18:00 .



Enables **dynamic, context-based authorization**.

Single Sign-On (SSO)

Definition:

Authenticate once to access multiple systems without re-entering credentials.

Benefits:

- Improves user experience
- Reduces password fatigue
- Simplifies centralized access management

Risks:

- Single point of failure if SSO server compromised

 Combine SSO with **MFA** for secure convenience.

Federated Identity Management (FIdM)

Definition:

Allows users to authenticate across multiple organizations or domains using shared trust.

Protocols:

- **SAML (Security Assertion Markup Language)** – enterprise web apps
- **OAuth 2.0** – delegated authorization
- **OpenID Connect (OIDC)** – user authentication layer over OAuth

Examples:

- Login with Google, Microsoft, or Facebook (OIDC)
- Enterprise federation between business partners (SAML)

Identity Providers (IdP) & Service Providers (SP)

IdP (Identity Provider): authenticates users and issues tokens

SP (Service Provider): trusts IdP and provides services

```
[User] → [Identity Provider (IdP)] → [Service Provider (SP)]
```

Examples:

- IdP: Azure AD, Okta, Ping Identity
- SP: Salesforce, AWS Console, Office 365

 Federation = "trust relationship between two domains."

Identity Lifecycle Management

Stages of user identity:

1. **Provisioning:** create and assign roles/access
2. **Review:** periodic verification of privileges
3. **Modification:** update access when job changes
4. **Deprovisioning:** remove access immediately when user leaves

 Automated lifecycle management ensures compliance and minimizes insider risk.

Directory Services

Centralized identity databases:

- **Active Directory (AD)** — LDAP/Kerberos-based
- **OpenLDAP, FreeIPA, AWS Directory Service**
- Manage users, groups, policies, and trust relationships

 Integrate directory services with SSO and MFA for full IAM solution.

Account Policies & Auditing

- Enforce strong password and lockout policies
- Limit concurrent logins and session durations
- Regularly audit:
 - Dormant accounts
 - Privileged accounts
 - Group memberships

Logging: essential for forensic analysis and compliance.

Privileged Access Management (PAM)

Controls high-risk administrative credentials.

- Vault admin passwords
- Monitor and record privileged sessions
- Rotate credentials automatically
- Integrate with SIEM for alerting

 Protects “keys to the kingdom” from insider threats.

Best Practices Summary

- Enforce **MFA** and **SSO with Federation**
- Apply **Least Privilege** and **Separation of Duties**
- Regularly review and audit access rights
- Deprovision accounts promptly
- Use **RBAC/ABAC** and centralized IAM for scalability

End of Chapter 14

Next: [Chapter 15 — Risk Management & Cryptography](#)